
Informe de pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta

Arturo Marin

7 de octubre de 2026

Índice

1. Datos generales	2
2. Pre-pentesting	2
3. Sala 1 — Pentesting Fundamentals	3
4. Sala 2 — Basic Pentesting	4
4.1. Escaneo y enumeración	4
4.2. Explotación y post-explotación	4
4.3. Cadena de ataque	5
5. Sala 3 — Vulnversity	5
5.1. Escaneo	5
5.2. Explotación	6
5.3. Post-explotación	7
5.4. Cadena de ataque	7
6. Hallazgos	7
7. Resumen ejecutivo de hallazgos	12
8. Post-pentesting: recomendaciones	14
9. Protocolo de contingencia	14
10. Herramientas	16
11. Anexos	16
12. Fuentes	17

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista	Arturo Marin
DNI	44746213
Username TryHackMe	marinarturo
Email institucional	marinarturo@uch.edu.ar
Sala de elección (Nivel 2)	Vulnversity
Branch en GitHub	marin-arturo
Repositorio	https://github.com/UCHSeguridad2026/TP_THM.git
Fecha de inicio	6 de octubre de 2026
Fecha de cierre	7 de octubre de 2026
Tipo de prueba	Caja negra, sobre las IP asignadas por TryHackMe

2. Pre-pentesting

Alcance del trabajo

Dentro del alcance quedaron exclusivamente tres salas de TryHackMe, autorizadas por la cátedra:

1. Pentesting Fundamentals (<https://tryhackme.com/room/pentestingfundamentals>), sala teórica.
2. Basic Pentesting (<https://tryhackme.com/room/basicpentestingjt>). Máquina de laboratorio 10.67.154.134 (NetBIOS BASIC2), atacada desde 10.67.134.141.
3. Vulnversity (<https://tryhackme.com/room/vulnversity>), sala de nivel 2 elegida por el alumno. IP inicial 10.67.178.161. Tras reiniciar la máquina, la plataforma asignó 10.65.174.55. Es el mismo objetivo en dos sesiones.

Quedó fuera de alcance cualquier host que no fuera la máquina desplegada en esas salas, cualquier sistema de la universidad o de terceros, la denegación de servicio y la ingeniería social sobre personas reales. El puesto de ataque (Kali, conectado por la VPN de TryHackMe) se usó solo como origen de las pruebas.

Reglas de Enfrentamiento (ROE)

- Autorización escrita de la cátedra, limitada a los laboratorios de esta guía.
- Cada prueba se dirigió a la IP que TryHackMe mostraba para esa máquina y en esa sesión.
- No se ejecutaron pruebas de denegación de servicio ni floods.
- La fuerza bruta de SSH se limitó al usuario que la propia sala había identificado y a la lista `rockyou.txt`.

- No se atacaron máquinas de otros estudiantes ni servicios fuera de la VPN del laboratorio.
- Las pruebas prácticas se realizaron el 6 y el 7 de octubre de 2026.
- Las contraseñas y las flags no se publican en este informe. El Anexo C contiene su hash SHA-256.

Autorización

Declaro que conté con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para trabajar sobre los entornos de TryHackMe indicados en el alcance. La carta de autorización de la actividad A08, a nombre del cliente ficticio INSECUR S.A., define ese límite. No se probó ningún sistema fuera de ese sandbox.

Metodología utilizada

El trabajo siguió el **PTES** (*Penetration Testing Execution Standard*): pre-engagement, reconocimiento, escaneo, enumeración, explotación, post-explotación y reporte. Se eligió porque cubre el encargo completo, incluido el informe y la remediación, y porque coincide con las fases que la guía de la actividad pide documentar.

En las superficies web se usó como referencia el **OWASP Web Security Testing Guide** y la clasificación OWASP Top 10:2021. **OSSTMM** y **NIST SP 800-115** se tomaron como marcos de apoyo (el primero visto en la sala teórica, para telecomunicaciones; el segundo, como guía de técnicas de assessment). La sala teórica no tenía máquina: su resultado es el marco con el que se leyeron las dos máquinas siguientes.

3. Sala 1 — Pentesting Fundamentals

Sala teórica, sin máquina. Quedó terminada con 5 tareas y 72 puntos, a nombre del usuario `marinarturo`. La captura está en `evidencias/reconocimiento/sala1_pentesting_fundamentals_completada.png`.



Figura 1: Cierre de Pentesting Fundamentals. Username `marinarturo` visible.

Conceptos que después se aplicaron en las máquinas:

- Actores: White Hat (autorizado), Black Hat (sin autorización y con daño), Grey Hat (sin autorización, aunque no busque daño). Esta actividad es White Hat.
- El documento que fija el permiso, el alcance y las restricciones es el Rules of Engagement.
- Information Gathering corresponde a la información pública (OSINT). En estas salas el reconocimiento útil fue activo, contra la IP del laboratorio, porque no hay una organización real que investigar.
- Marcos: OSSTMM para telecomunicaciones, OWASP para web, NIST SP 800-115 para assessment, PTES para el ciclo completo.
- Modelos de prueba: caja negra (este trabajo), caja blanca y caja gris.
- Fases usadas en el informe: autorización, reconocimiento, escaneo y enumeración, explotación, post-explotación y reporte.

4. Sala 2 — Basic Pentesting

4.1. Escaneo y enumeración

`nmap -sC -sV` contra `10.67.154.134` mostró cuatro puertos:

Puerto	Servicio	Versión
22	SSH	OpenSSH 8.2p1 (Ubuntu)
80	HTTP	Apache 2.4.41
139	Samba	smbd 4.6.2
445	Samba	smbd 4.6.2

La página del puerto 80 era una fachada (“Undergoing maintenance”). En el código fuente había un comentario que apuntaba a las notas de desarrollo. Gobuster, con la lista `dirb/common.txt`, encontró `/development` (HTTP 301). El listado de ese directorio estaba habilitado y exponía `dev.txt` y `j.txt`.

`dev.txt` menciona Apache Struts 2.5.12 y que el SMB ya estaba configurado. Struts no se usó: era un distractor. `j.txt`, firmado por K, dice que auditó `/etc/shadow`, que el hash de J se crackeaba con facilidad y que había que cambiar esa contraseña.

En Samba, `smbclient -L //10.67.154.134/ -N` mostró el recurso `Anonymous` sin contraseña. Adentro, `staff.txt` está firmado por Kay y nombra a Jan. Con eso, J y K pasan a ser los usuarios del sistema `jan` y `kay`.

4.2. Explotación y post-explotación

La corrida documentada en la captura es:

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt 10.67.154.134 ssh
```

Hydra 9.5 la inició el 6 de octubre de 2026 a las 05:10:15, desde `10.67.134.141`. Obtuvo un login válido para `jan`. La contraseña no se transcribe acá.

Como `jan`, `sudo -l` no devolvía privilegios. La clave privada `/home/kay/.ssh/id_rsa` estaba en modo `-rw-r--r--`, así que `jan` pudo leerla. Tenía `passphrase`. Se extrajo el hash con `ssh2john` y John the Ripper la resolvió con `rockyou.txt`. Con `ssh -i` se entró como `kay`.

`sudo -l` de `kay` devolvía `(ALL : ALL) ALL`. `sudo su` entregó una shell de root. La prueba de compromiso de la sala está en `pass.bak`, del home de `kay`. Su valor va solo como hash en el Anexo C.

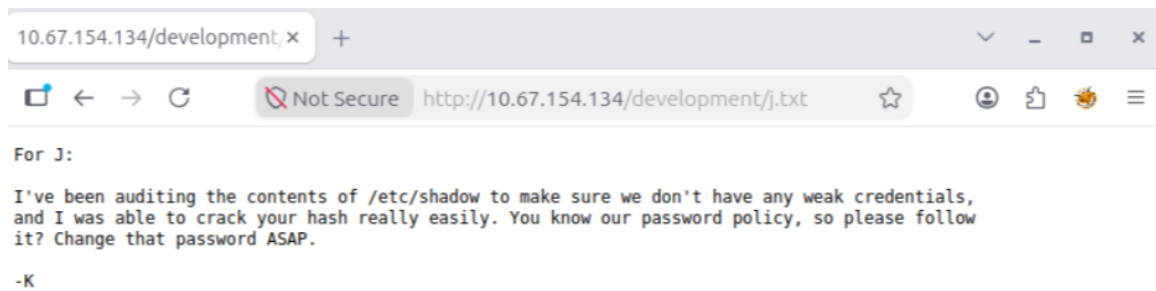


Figura 2: `j.txt` servido sin autenticación en el puerto 80.

La captura correspondiente queda en `evidencias/post/kay_pass_bak_final.png` y no se incrusta en este PDF para no repetir el secreto en el cuerpo del informe.

La sala figura completada a nombre de `marinarturo`.

4.3. Cadena de ataque

Externo, sin credenciales. Listado web y share SMB anónimo identifican a `jan`. La contraseña débil da SSH como `jan`. La clave privada de `kay`, legible y con passphrase débil, da la sesión de `kay`. El `sudo` sin restricción da root. La máquina queda comprometida por completo.

5. Sala 3 — Vulniversity

5.1. Escaneo

Un `nmap -sC -sV` de los mil puertos habituales, el 7 de octubre de 2026 a las 00:00 (-0300), Nmap 7.991, vio el host arriba y los mil puertos cerrados. La web no está en 80 ni en 443.

El escaneo completo fue:

```
nmap -sC -sV -p- -oN nmap_vulniversity_full.txt 10.67.178.161
```

Corrió de 00:10:29 a 00:59:39 (2949 segundos). Seis puertos abiertos:

```

root@ip-10-67-134-141:~# hydra -l jan -P /usr/share/wordlists/rockyou.txt 10.67.
154.134 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-06 05:10:
15
[WARNING] Many SSH configurations limit the number of parallel tasks, it is reco
mmended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:
14344398), ~896525 tries per task
[DATA] attacking ssh://10.67.154.134:22/

```

Figura 3: Inicio de la fuerza bruta SSH contra jan. IP objetivo visible.

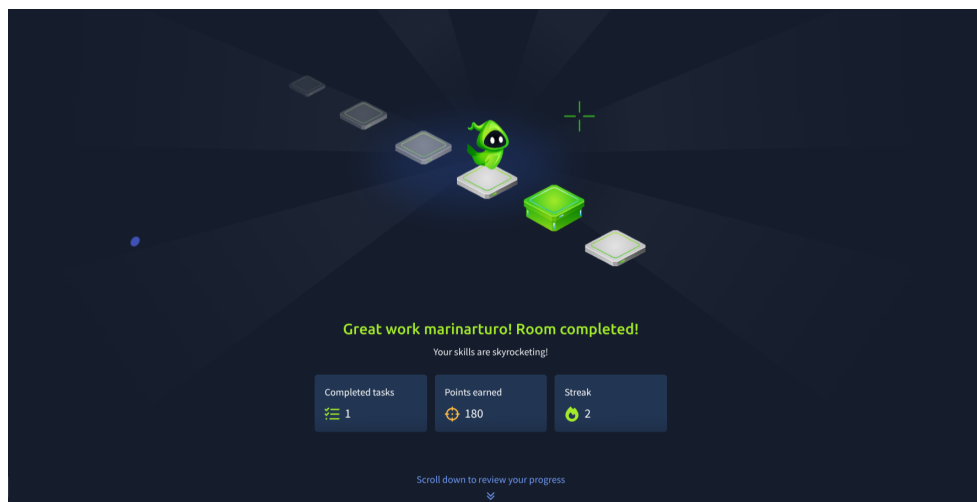


Figura 4: Cierre de Basic Pentesting. Username marinarturo visible.

Puerto	Servicio	Versión
21	FTP	vsftpd 3.0.5
22	SSH	OpenSSH 8.2p1 Ubuntu
139	NetBIOS / Samba	smbd 4
445	NetBIOS / Samba	smbd 4
3128	Proxy HTTP	Squid 4.10
3333	HTTP	Apache 2.4.41 (Ubuntu)

El título HTTP del puerto 3333 es “Vuln University”. FTP, SSH, Samba y Squid se enumeraron para responder la sala. El compromiso no pasó por ellos.

5.2. Explotación

Gobuster contra `http://10.67.178.161:3333` llevó a `/internal/index.php`, un formulario de subida. El servidor aceptó un script PHP renombrado a `shell.phtml`. El archivo quedó publicado en `/internal/uploads/shell.phtml`, directorio con listado abierto, y Apache lo ejecutó.

Un listener `nc -lvnp 443` recibió la conexión y dejó una shell como `www-data`. La sesión de las capturas de post-explotación corresponde a 10.65.174.55: la máquina del laboratorio se reinició y

```

.../UCH/Seguridad x nmap -sC -sV -oN nmap_vulniversity.txt 10.67.178.161
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-07 00:06 -0300
Nmap scan report for 10.67.178.161
Host is up (0.14s latency).
All 1000 scanned ports on 10.67.178.161 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.05 seconds

.../UCH/Seguridad ) █

```

Figura 5: Primer escaneo de Vulniversity: 10.67.178.161, mil puertos cerrados.

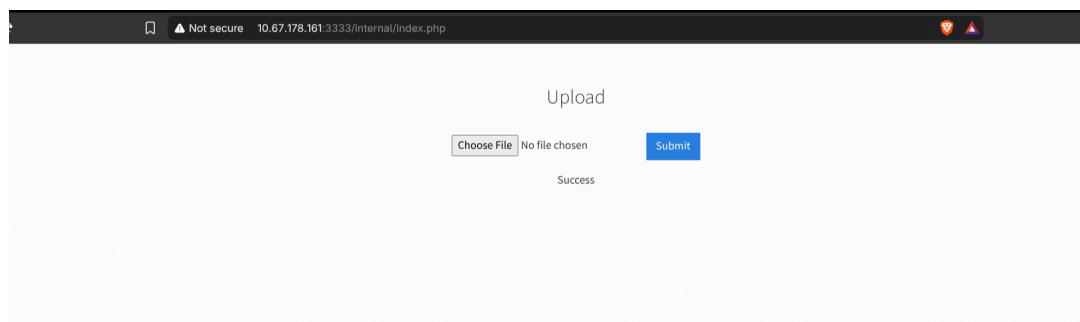


Figura 6: Formulario de `/internal/` en el puerto 3333. La página respondió Success.

TryHackMe cambió la IP. El mecanismo fue el mismo.

5.3. Post-explotación

`/home/bill/user.txt` era legible por `www-data`. Para escalar se listaron binarios SUID con `find` y permiso 4000. `/bin/systemctl` estaba como `-rwsr-xr-x`, dueño root. Con ese binario se registró un servicio `oneshot` en `/tmp` cuyo `ExecStart` leía `/root/root.txt`. `systemctl link` y `systemctl enable --now` lo ejecutaron como root. La prueba quedó en `/tmp/rootflag.txt`. El valor no se transcribe; el hash está en el Anexo C y la captura en `evidencias/post/vuln_rootflag.png`.

La sala quedó al 100% (cinco tareas), con la IP 10.65.174.55 visible en la interfaz y el usuario de la cuenta en la sesión de TryHackMe.

5.4. Cadena de ataque

El puerto web no aparece en un escaneo corto. El formulario de `/internal/` acepta un `.phtml` y lo ejecuta dentro del webroot. Eso da código remoto como `www-data`. `systemctl` con SUID convierte esa sesión en root.

6. Hallazgos

Cada fila describe un defecto del objetivo. El firewall del puesto de ataque no es un hallazgo: la política restrictiva estaba en la máquina desde la que se lanzó la prueba, no en el servidor de INSECUR. La subida de `shell.phtml` y la ejecución remota son el mismo defecto, no dos.

H-01 — Listado de directorios

Campo	Valor
-------	-------

ID del hallazgo	H-01
Fase	Escaneo. También habilita el reconocimiento posterior.
Descripción	<code>/development</code> en Basic Pentesting lista su contenido sin autenticación y entrega <code>dev.txt</code> y <code>j.txt</code> .
Componente afectado	Apache 2.4.41, puerto 80, 10.67.154.134
Categoría (OWASP / CWE)	A05:2021 Security Misconfiguration. CWE-548.
CVE	No aplica. Es configuración, no un fallo de la versión.
CVSS estimado	Medio
Evidencia	<code>evidencias/reconocimiento/web_development_listado.png</code>
Herramienta utilizada	Gobuster y el navegador
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	<code>Options -Indexes</code> en Apache. Negar el acceso HTTP a directorios que no sean públicos.
Riesgo residual tras aplicar	Bajo

H-02 — Notas internas publicadas

Campo	Valor
ID del hallazgo	H-02
Fase	Reconocimiento
Descripción	<code>j.txt</code> informa que el hash de J en <code>/etc/shadow</code> es débil. <code>dev.txt</code> detalla software y servicios del servidor. Cualquier cliente del puerto 80 puede leerlos.
Componente afectado	Contenido estático del mismo Apache, puerto 80
Categoría (OWASP / CWE)	A01:2021 Broken Access Control. CWE-200.
CVE	No aplica.
CVSS estimado	Bajo, por sí solo. Es el dato que orienta H-04.
Evidencia	<code>evidencias/reconocimiento/j_txt.png</code> , <code>dev_txt.png</code>
Herramienta utilizada	Navegador
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	No publicar notas de desarrollo en el webroot. Sacar del servidor los archivos que no sirven a la aplicación.

Riesgo residual tras
aplicar

H-03 — Share SMB anónimo

Campo	Valor
ID del hallazgo	H-03
Fase	Escaneo / enumeración
Descripción	El recurso Samba Anonymous acepta conexión con -N y entrega staff.txt , que identifica a Jan y a Kay.
Componente afectado	Samba smbd 4.6.2, puertos 139 y 445
Categoría (OWASP / CWE)	A05:2021 Security Misconfiguration. CWE-284.
CVE	No aplica.
CVSS estimado	Medio
Evidencia	evidencias/escaneo/smb_shares.png, smbclient_anonymous.png, staff_txt_nombres.png
Herramienta utilizada	smbclient
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar el acceso de invitado. Exigir autenticación en cada share y no guardar avisos internos en un recurso anónimo.
Riesgo residual tras aplicar	Bajo

H-04 — Contraseña débil en SSH

Campo	Valor
ID del hallazgo	H-04
Fase	Explotación
Descripción	La contraseña de jan está en rockyou.txt y tiene 7 caracteres. Hydra obtuvo una sesión SSH. No había bloqueo por intentos.
Componente afectado	OpenSSH 8.2p1, puerto 22, usuario jan
Categoría (OWASP / CWE)	A07:2021 Identification and Authentication Failures. CWE-521.
CVE	No aplica.
CVSS estimado	Alto

Evidencia	<code>evidencias/explotacion/hydra_ssh_jan.png</code> , <code>post/ssh_jan_whoami_id.png</code>
Herramienta utilizada	Hydra 9.5 y el cliente OpenSSH
Impacto en la Tríada CIA	Confidencialidad e integridad
Salvaguada propuesta	Política de longitud y de rechazo de contraseñas filtradas. MFA en SSH. <code>fail2ban</code> o un límite equivalente de intentos.
Riesgo residual tras aplicar	Bajo

H-05 — Clave privada SSH legible

Campo	Valor
ID del hallazgo	H-05
Fase	Post-explotación
Descripción	<code>/home/kay/.ssh/id_rsa</code> era legible por todos (<code>-rw-r--r--</code>). <code>jan</code> la copió. La passphrase estaba en <code>rockyou.txt</code> y John la recuperó. Con esa clave se abrió SSH como <code>kay</code> .
Componente afectado	OpenSSH, permisos del home de <code>kay</code>
Categoría (OWASP / CWE)	A01:2021 Broken Access Control. CWE-732.
CVE	No aplica.
CVSS estimado	Alto
Evidencia	<code>evidencias/post/crack_ssh_key_john.png</code>
Herramienta utilizada	<code>ssh2john</code> y John the Ripper
Impacto en la Tríada CIA	Confidencialidad e integridad
Salvaguada propuesta	Permisos <code>600</code> en claves privadas y <code>700</code> en <code>.ssh</code> . Passphrase larga y ausente de listas públicas. Rotar la clave que ya fue leída.
Riesgo residual tras aplicar	Bajo

H-06 — sudo sin restricción

Campo	Valor
ID del hallazgo	H-06
Fase	Post-explotación

Descripción	<code>sudo -l</code> como <code>kay</code> devuelve (ALL : ALL) ALL. <code>sudo su</code> entrega root. Un usuario de administración queda equivalente al superusuario.
Componente afectado	sudoers de la máquina BASIC2
Categoría (OWASP / CWE)	A01:2021 Broken Access Control. CWE-269.
CVE	No aplica.
CVSS estimado	Crítico
Evidencia	evidencias/post/escalada_root.png
Herramienta utilizada	sudo, en la sesión SSH de <code>kay</code>
Impacto en la Tríada CIA	Confidencialidad, integridad y disponibilidad
Salvaguarda propuesta	Mínimo privilegio: listar los comandos que <code>kay</code> necesita. No otorgar ALL. Separar la cuenta de administración del uso diario.
Riesgo residual tras aplicar	Bajo. Sin ese cambio, el hallazgo sigue en crítico.

H-07 — Subida de archivos que ejecuta código

Campo	Valor
ID del hallazgo	H-07
Fase	Explotación
Descripción	<code>/internal/index.php</code> acepta un archivo y lo guarda en <code>/internal/uploads/</code> , con listado abierto y ejecución de PHP. La extensión <code>.phtml</code> pasó el filtro. Pedir esa URL ejecutó el script y devolvió una shell como <code>www-data</code> .
Componente afectado	Apache 2.4.41, puerto 3333, aplicación Vuln University
Categoría (OWASP / CWE)	A05:2021 Security Misconfiguration y A03:2021 Injection. CWE-434.
CVE	No aplica. El defecto es de la aplicación, no un CVE de Apache 2.4.41.
CVSS estimado	Crítico
Evidencia	evidencias/explotacion/vuln_formulario_internal.png, vuln_uploads_shell_phtml.png, vuln_reverse_shell.png
Herramienta utilizada	Gobuster, el formulario de subida y netcat
Impacto en la Tríada CIA	Confidencialidad, integridad y disponibilidad

Salvaguada propuesta	Validar extensión y contenido en el servidor, con una lista blanca. Renombrar el archivo guardado. Guardarlo fuera del webroot. Deshabilitar la ejecución de scripts en el directorio de uploads. Quitar el listado de directorios.
Riesgo residual tras aplicar	Bajo

H-08 — systemctl con bit SUID

Campo	Valor
ID del hallazgo	H-08
Fase	Post-explotación
Descripción	<code>/bin/systemctl</code> tiene el bit SUID y dueño root. www-data registró un servicio en <code>/tmp</code> y lo activó. El servicio corrió como root y leyó <code>/root/root.txt</code> .
Componente afectado	<code>/bin/systemctl</code> en la máquina de Vulniversity
Categoría (OWASP / CWE)	A01:2021 Broken Access Control. CWE-269.
CVE	No aplica. El binario no necesita un CVE si el SUID es de configuración local.
CVSS estimado	Crítico
Evidencia	<code>evidencias/post/vuln_rootflag.png</code>
Herramienta utilizada	<code>find</code> (permiso 4000) y <code>systemctl</code>
Impacto en la Tríada CIA	Confidencialidad, integridad y disponibilidad
Salvaguada propuesta	Sacar el bit SUID de <code>systemctl</code> . Revisar el resto de los SUID y dejar solo los que el sistema necesita. Impedir que el usuario del servicio web escriba unidades de <code>systemd</code> .
Riesgo residual tras aplicar	Bajo

7. Resumen ejecutivo de hallazgos

Las dos máquinas se comprometieron hasta root. En Basic Pentesting el camino fue información de más, una contraseña corta y privilegios de sudo mal recortados. En Vulniversity fue una subida de archivos ejecutable y un binario SUID. No hace falta un exploit de una CVE publicada: alcanza con la configuración.

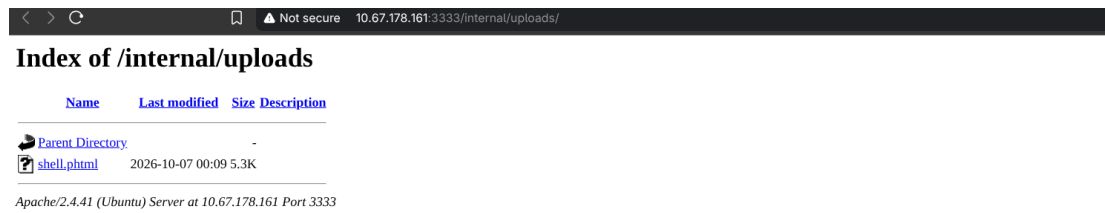


Figura 7: Listado de /internal/uploads/ con shell.phtml. Apache 2.4.41, puerto 3333.

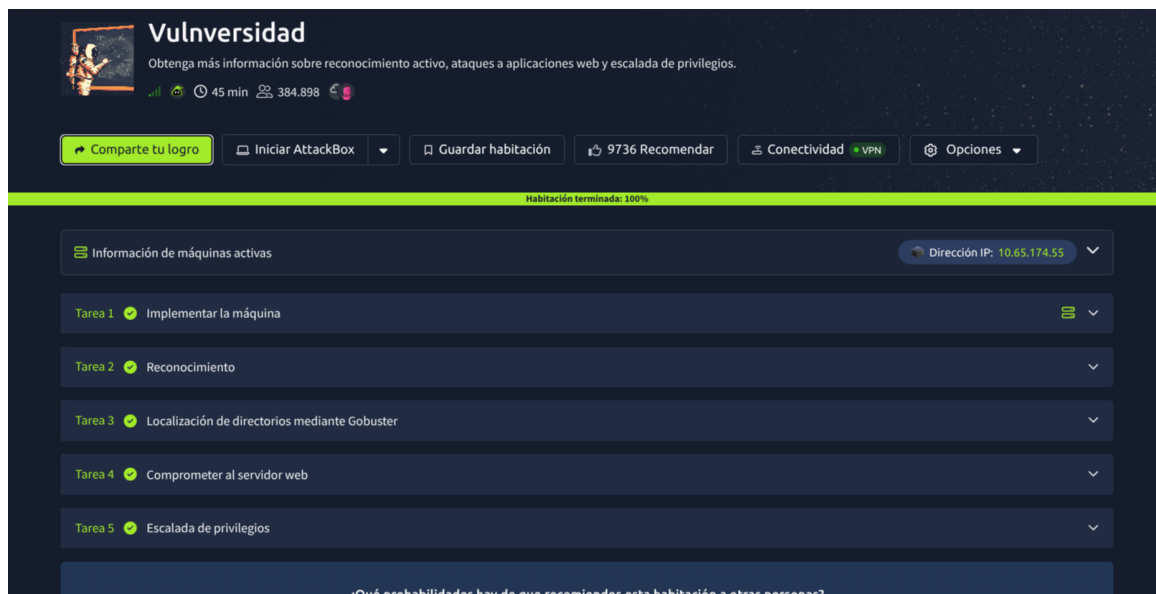


Figura 8: Vulnversity terminada. IP de la segunda sesión visible.

Severidad	Cantidad	ID de hallazgos
Crítico	3	H-06, H-07, H-08
Alto	2	H-04, H-05
Medio	2	H-01, H-03
Bajo	1	H-02
Total	8	

Prioridad de corrección: H-07 y H-08 en el servidor web, y H-06 en cualquier host donde una cuenta de servicio tenga sudo total. H-04 y H-05 cierran el acceso inicial y el movimiento lateral de la primera máquina.

8. Post-pentesting: recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Ordenadas por la severidad del hallazgo que cierran.

1. Sacar la ejecución de scripts del directorio de uploads, guardar los archivos fuera del webroot y validar tipo y extensión en el servidor (H-07).
2. Quitar el SUID de `/bin/systemctl` y auditar el resto de los binarios con permiso 4000 (H-08).
3. Reemplazar `(ALL : ALL) ALL` por la lista corta de comandos que cada cuenta necesita (H-06).
4. Exigir contraseñas que no estén en listas públicas, MFA en SSH y bloqueo por intentos (H-04).
5. Poner las claves privadas en 600, rotar la de `kay` y exigir una passphrase que no esté en `rockyou.txt` (H-05).
6. Deshabilitar el share anónimo de Samba (H-03) y el listado de directorios de Apache (H-01).
7. Borrar del webroot las notas de desarrollo (H-02).

Struts 2.5.12 figuraba en `dev.txt` y no se explotó. Igual conviene confirmar que ese componente no está instalado, porque la nota lo deja como superficie a revisar.

Recomendaciones administrativas (políticas y procesos)

- Política de contraseñas escrita, con longitud mínima y rechazo de contraseñas ya filtradas. La nota de K pedía el cambio y `jan` no lo había hecho: el control existía en el texto y no en el sistema.
- Revisión periódica de sudoers, de permisos de `.ssh` y de binarios SUID. Una vez por trimestre alcanza para un entorno de este tamaño.
- Separar ambientes. Las notas de desarrollo no se publican en el mismo host que atiende al usuario.
- Alta y baja de cuentas documentada. `jan` y `kay` quedaron con más permiso del que necesitaban para su tarea.
- Repetir este ejercicio después de aplicar los cambios, sobre una copia del servidor, para verificar que las ocho vías quedaron cerradas.

9. Protocolo de contingencia

Escenario de falla

El procedimiento con más chance de cortar un servicio, si se repitiera fuera del laboratorio, es la subida de un script ejecutable al webroot (H-07) seguida del uso de un binario SUID (H-08). En producción eso permite modificar o detener el sitio, crear usuarios y leer datos del servidor. La fuerza bruta de SSH (H-04), llevada sin el límite de la sala, puede además bloquear cuentas

o degradar el servicio de acceso remoto.

Impacto sobre la continuidad del negocio

Se vería afectado el sitio que INSECUR publica para sus usuarios (en el laboratorio, la aplicación “Vuln University” y el servidor de Basic Pentesting). Mientras el host esté comprometido, el contenido deja de ser confiable y el servicio puede quedar caído. Con un snapshot previo, la ventana es del orden de unas horas. Sin backup, la reconstrucción manual la alarga a un día o más. Si el atacante llegó a datos personales, se suma el aviso a los titulares y a la dirección.

Plan de respuesta

1. **Activación.** Alerta por un archivo nuevo en el directorio de uploads, un proceso hijo de Apache que abre una conexión saliente, o un servicio desconocido creado por `systemctl`. También, muchos fallos de login en SSH en pocos minutos.
2. **Contención (primeros 15 minutos).** Sacar el host del balanceo o de la publicación. Cortar el egress del servidor para frenar una shell inversa. No apagarlo de inmediato si todavía hace falta la memoria para el análisis. Bloquear la IP de origen en el perímetro. Publicar una página de mantenimiento desde otro equipo.
3. **Recuperación.** Restaurar el último backup anterior al archivo subido. Rotar contraseñas y claves SSH. Aplicar las salvaguardas de H-06, H-07 y H-08 antes de volver a publicar. Verificar con un escaneo y con una prueba de subida que el directorio ya no ejecuta scripts.
4. **Comunicación.** Aviso interno a quien opera la plataforma y a la dirección de INSECUR. Si hubo acceso a datos de usuarios, aviso a esos usuarios. En el marco de esta materia, también al docente. No se publica el detalle técnico hasta que el servicio esté restaurado y las credenciales rotadas.
5. **Post-mortem.** Línea de tiempo, qué control falló (filtro de subida y SUID), qué backup se usó, y una reprobación. El resultado se agrega a este informe como anexo de verificación.

RTO y RPO estimados

Estas cifras son el objetivo para el equivalente productivo del servidor web del laboratorio, no una medición tomada durante la prueba.

RTO (Recovery Time Objective): 4 horas, desde la decisión de aislar el host hasta el sitio restaurado y publicado de nuevo.

RPO (Recovery Point Objective): 24 horas, correspondiente a un backup diario. Los cambios legítimos de ese día se vuelven a cargar a mano.

10. Herramientas

Herramienta	Para qué se usó
Nmap 7.991	Puertos y versiones. En Vulnversity, <code>-p-</code> hizo falta porque el servicio web estaba en el puerto 3333.
Gobuster	Directorios web con <code>dirb/common.txt</code> .
smbclient	Shares de Samba sin credenciales.
Hydra 9.5	Fuerza bruta de SSH contra el usuario que la sala ya había señalado.
ssh2john y John the Ripper	Passphrase de la clave privada de <code>kay</code> , con <code>rockyou.txt</code> .
Cliente OpenSSH	Sesiones de <code>jan</code> y de <code>kay</code> .
Netcat	Listener del canal de vuelta en el puerto 443.
<code>find</code> y <code>systemctl</code>	Búsqueda del SUID y ejecución del servicio como root.

No se usó un exploit público de una CVE. Las versiones (Apache 2.4.41, OpenSSH 8.2p1, vsftpd 3.0.5, Squid 4.10, Samba) se registraron para descartar ese camino y para dejar la línea de base del objetivo. Struts 2.5.12 quedó anotado como mención en `dev.txt`, sin explotación.

11. Anexos

Anexo A — Bitácora de comandos

- `bitacora/clase_20261006_basic_pentesting.txt`
- `bitacora/clase_20261007_vulnversity.txt`
- `bitacora/nmap_vulnversity.txt`
- `bitacora/nmap_vulnversity_full.txt`

Las contraseñas, la passphrase y las flags están reemplazadas por `[REDACTED]` en las bitácoras.

Anexo B — Capturas de pantalla

Carpeta `evidencias/`, separada por fase. Las de Basic Pentesting cubren la web, Samba, Hydra, la escalada y el cierre de la sala. Las de Vulnversity cubren el escaneo corto, el formulario, `shell.phtml`, la shell y el cierre al 100 %.

La guía pide, en cada captura crítica, el username de TryHackMe, la fecha y hora del sistema y la IP objetivo en el mismo cuadro. En este material el username aparece en las pantallas de sala completada, y la IP aparece en las capturas de terminal y de navegador. No están las tres marcas en una sola imagen. Se entregan las capturas que se tomaron durante la prueba.

Anexo C — Hashes de las pruebas obtenidas

SHA-256 de la cadena exacta, sin salto de línea, como indica la guía (`echo -n`). No se pega la flag.

F-01	Pentesting Fundamentals, flag de cierre 583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6
F-02	Basic Pentesting, contenido de <code>pass.bak</code> 3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
F-03	Vulnversity, <code>/home/bill/user.txt</code>

```
d324bd433001e5bdfc39e04d794539c15b51982a5bf6fc78efea46369b7bf956
F-04  Vulniversity, /root/root.txt
      cfbcb740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
```

F-02 no es una flag con formato THM{...}. Es la prueba que la sala pide al final, léida como kay después de llegar a root.

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados de TryHackMe y con fines exclusivamente académicos. No apliqué estas técnicas sobre sistemas reales sin autorización.

Arturo Marin
DNI 44746213

7 de octubre de 2026

Firma del estudiante

Fecha

12. Fuentes

- TryHackMe. *Pentesting Fundamentals*. <https://tryhackme.com/room/pentestingfundamentals>
- TryHackMe. *Basic Pentesting*. <https://tryhackme.com/room/basicpentestingjt>
- TryHackMe. *Vulniversity*. <https://tryhackme.com/room/vulniversity>
- OWASP Foundation. *Web Security Testing Guide*. <https://owasp.org/www-project-web-security-testing-guide/>
- OWASP Foundation. *OWASP Top 10:2021*.
- NIST. *Technical Guide to Information Security Testing and Assessment (SP 800-115)*, 2008.
- Penetration Testing Execution Standard. <http://www.pentest-standard.org/>